

Multi-Framework Compliance Report

Document:	sample_azure_compliance_document.txt
Analyzed By:	khizarahmedd3@gmail.com
Analysis Date:	2025-11-10
Overall Score:	62/100
Status:	Partial
Frameworks Analyzed:	4

Framework Compliance Scores

Framework	Score	Status
Azure Best Practices	84/100	Compliant
GDPR	51/100	Non-Compliant
ISO 27001	58/100	Non-Compliant
ISO 27018	55/100	Non-Compliant

Executive Summary

Multi-framework compliance analysis complete. Overall score: 62/100 (Partial). Analyzed against 4 frameworks: azure, gdpr, iso27001, iso27018.

Detailed Framework Analysis

Azure Best Practices

Score:	84/100
Status:	Compliant

Recommendation:

While the document covers many Azure security aspects, enhance security by implementing standardized hardened workstation configurations for administrators accessing Azure resources, as recommended by Azure Best Practices. Document the specific hardening standards applied to these workstations.

Gaps Identified:

- Lack of explicit mention of standardized hardened workstation configurations for administrators accessing Azure resources.
- No specific details on how the documented ISMS is maintained and updated to reflect changes in Azure services and security best practices.

Compliant Areas:

- Use of Azure Active Directory (Azure AD) for authentication.
- Mandatory Multi-Factor Authentication (MFA) for all administrative accounts.
- Implementation of Role-Based Access Control (RBAC) following the principle of least privilege.
- Configuration of Conditional Access policies to enforce security requirements.
- Deployment of Azure Firewall for centralized network security management.
- Enabling encryption at rest using Azure Storage Service Encryption.
- Use of Azure Key Vault for managing secrets, keys, and certificates.
- Enabling Transparent Data Encryption (TDE) for all SQL databases.
- Implementation of Azure Disk Encryption for all Virtual Machines.
- Enabling Azure Monitor for all subscriptions and resources.
- Activating Azure Defender for Cloud Security Posture Management.
- Using Azure Sentinel for Security Information and Event Management (SIEM).
- Assignment of Azure Policy initiatives to enforce organizational standards.
- Alignment of compliance policies with GDPR, ISO 27001, and ISO 27018 requirements.

Key Requirements:

- Secure connectivity to your database using secure connection strings
- Use access management
- Data encryption
- SQL Database auditing
- SQL Database threat detection

Priority Actions:

1. Implement and document standardized hardened workstation configurations for administrators.
2. Establish a process for regularly reviewing and updating the ISMS documentation to reflect changes in Azure services and security best practices.
3. Ensure all administrators are trained on the hardened workstation configuration and its importance for Azure security.

GDPR (General Data Protection Regulation)

Score:	51/100
--------	--------

Status:	Partial
----------------	---------

Recommendation:

Conduct a Data Protection Impact Assessment (DPIA) for all high-risk processing activities as required by GDPR Article 35. While the document mentions 'Privacy by Design principles are followed,' a formal DPIA process with documented assessments is crucial for demonstrating compliance, especially when processing sensitive data or using new technologies.

Gaps Identified:

- Lack of documented Data Protection Impact Assessments (DPIAs) for high-risk processing activities (Article 35). While Privacy by Design is mentioned, DPIA execution is not evident.
- Absence of details regarding the designation of a Data Protection Officer (DPO) and their responsibilities (Articles 37-39). The document doesn't explicitly state whether a DPO has been appointed or how their role is fulfilled.
- Insufficient information on the lawful basis for processing personal data (Article 6). While data classification and DLP are mentioned, the specific legal grounds (consent, contract, legal obligation, etc.) for processing different types of personal data are not clearly defined.
- Limited details on international data transfer mechanisms (Chapter V). The document doesn't specify how data transfers outside the EU are handled and whether appropriate safeguards (e.g., Standard Contractual Clauses) are in place.

Compliant Areas:

- Implementation of security measures such as encryption at rest and in transit, multi-factor authentication, and network segmentation (Article 32).
- Documentation of data subject rights procedures per GDPR Articles 15-22, indicating a framework for handling data access, rectification, erasure, and portability requests.
- Establishment of breach notification procedures complying with GDPR Articles 33-34, demonstrating a process for reporting data breaches to supervisory authorities and affected individuals.
- Implementation of Data Loss Prevention (DLP) policies to protect Personally Identifiable Information (PII).

Key Requirements:

- Lawful basis for processing personal data (Article 6): Organizations must identify and document a valid legal basis (e.g., consent, contract, legal obligation) for each processing activity.
- Data subject rights (Articles 12-23): Individuals have the right to access, rectify, erase, restrict processing, and port their personal data. Organizations must have procedures in place to facilitate these rights.
- Security of processing (Article 32): Implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including encryption, access controls, and regular security testing.
- Data breach notification (Articles 33-34): Notify the supervisory authority and affected individuals of a data breach within 72 hours of discovery, if the breach is likely to result in a risk to the rights and freedoms of individuals.
- Data Protection Impact Assessment (DPIA) (Article 35): Conduct a DPIA for processing activities that are likely to result in a high risk to the rights and freedoms of individuals.
- Data Protection Officer (DPO) designation (Articles 37-39): Appoint a DPO if the organization's core activities involve regular and systematic monitoring of data subjects on a large scale or processing of special categories of data.

Priority Actions:

1. Conduct a comprehensive data mapping exercise to identify all personal data processed, the purpose of processing, and the lawful basis for each processing activity (Article 6).
2. Develop and implement a formal DPIA process, including templates and guidelines, to assess and mitigate privacy risks associated with high-risk processing activities (Article 35).
3. Determine whether a DPO is required under GDPR Article 37 and, if so, designate a qualified individual or team to fulfill this role.
4. Review and update data subject rights procedures to ensure they are compliant with GDPR Articles 12-23, including providing clear and concise information about how individuals can exercise their rights.

ISO 27001:2022

Score:	58/100
Status:	Partial

Recommendation:

Develop and document a comprehensive Information Security Management System (ISMS) that explicitly addresses all clauses of ISO 27001:2022, including defining the scope of the ISMS, risk assessment methodology, and continual improvement processes. Ensure that confidentiality agreements are documented, regularly reviewed, and signed by relevant parties as per ISO 27001:2022 requirement 6.6.

Gaps Identified:

- Lack of documented information security objectives as required by ISO 27001:2022 clause 5.2b. While the document mentions compliance with ISO 27001, it doesn't explicitly state the organization's information security objectives.
- Absence of documented confidentiality or non-disclosure agreements as required by ISO 27001:2022 control 6.6. The document doesn't mention the existence or management of such agreements.
- Missing details on physical security perimeters and entry controls as per ISO 27001:2022 controls 7.1 and 7.2. The document focuses on cloud security but lacks information on physical security measures.
- Lack of explicit mention of a mechanism for personnel to report observed or suspected information security events as required by ISO 27001:2022 control 6.8.
- The document mentions compliance with ISO 27001 Annex A.9, A.10, and A.12, but it does not provide sufficient detail on how these controls are implemented and maintained to meet the specific requirements of the standard. For example, the document mentions cryptographic controls but lacks details on key management practices.

Compliant Areas:

- Access control policies align with ISO 27001 Annex A.9 (Identity and Access Management section)
- Cryptographic controls follow ISO 27001 Annex A.10 requirements (Data Protection section)
- Operations security procedures comply with ISO 27001 Annex A.12 (Monitoring and Logging section)
- Incident management processes follow ISO 27001 Annex A.16 (Security alerts are configured and sent to the security operations team)

Key Requirements:

- Establish and maintain an Information Security Management System (ISMS)
- Define the scope of the ISMS
- Conduct information security risk assessments
- Implement information security controls based on risk assessment results
- Document and communicate information security policies
- Monitor and review the ISMS
- Continually improve the ISMS

Priority Actions:

1. Develop and document a comprehensive ISMS that addresses all clauses of ISO 27001:2022.
2. Define and document information security objectives that are measurable and aligned with the organization's business goals.
3. Implement a mechanism for personnel to report observed or suspected information security events.
4. Establish and document physical security perimeters and entry controls to protect areas containing information and associated assets.
5. Document and implement confidentiality or non-disclosure agreements with personnel and relevant interested parties.

ISO 27018:2019

Score:	55/100
Status:	Partial

Recommendation:

Enhance the document to explicitly address consent management mechanisms for PII processing in the cloud, detailing how consent is obtained, recorded, and revoked. Also, include specific details on how data subject rights (access, rectification, erasure, portability) are facilitated within the Azure environment, going beyond just stating that procedures are documented. Finally, clarify the circumstances under which cryptography is used to protect PII and provide information to customers about cryptographic capabilities.

Gaps Identified:

- Lack of detailed description of consent management mechanisms for PII processing.
- Insufficient detail on how data subject rights (access, rectification, erasure, portability) are facilitated within the Azure environment.
- Missing information regarding the circumstances in which cryptography is used to protect PII and the cryptographic capabilities provided to customers.
- Absence of explicit mention of providing secure log-on procedures for cloud service users under the customer's control (as per section 9.4.3 of ISO/IEC 27002, referenced by ISO 27018).

Compliant Areas:

- Implementation of Data Loss Prevention (DLP) policies to protect Personally Identifiable Information (PII).
- Documentation of Data Subject Rights procedures per GDPR Article 15-22.
- Breach notification procedures comply with GDPR Article 33-34.
- Encryption at rest enabled for all storage accounts using Azure Storage Service Encryption.
- Transparent Data Encryption (TDE) is enabled for all SQL databases.
- Azure Key Vault is used for managing secrets, keys, and certificates.

Key Requirements:

- PII protection in cloud environments.
- Consent management for PII processing.
- Support for data subject rights (access, rectification, erasure, portability).
- Transparency regarding PII processing activities.
- PII breach notification procedures.

Priority Actions:

1. Develop and document detailed consent management procedures for PII processing, including obtaining, recording, and revoking consent.
2. Create specific procedures for facilitating data subject rights requests (access, rectification, erasure, portability) within the Azure environment, including timelines and responsible parties.
3. Document the circumstances under which cryptography is used to protect PII and provide information to customers about cryptographic capabilities available to them.
4. Implement and document secure log-on procedures for cloud service users under the customer's control, aligning with ISO/IEC 27002 section 9.4.3.